

Glosario

- Seguridad de la información ¿= seguridad informática ¿= ciberseguridad:
- Amenazas:
- Vulnerabilidad:
- Impacto:
- Riesgo:
- Severidad:
- Las 5 Ps de la seguridad de la información:
- Los pilares de la seguridad de la información: CID
- Los 4 modelos de ataque:

RESUMEN SSI PARCIAL 1 TEORIA

Capítulo 1 – Fundamentos de la seguridad de la información

1.1 Tendencias en la gestión de seguridad de la información

La gestión de la seguridad de la información evolucionó desde las recomendaciones de buenas prácticas de la norma ISO-17799 (año 2000) hacia la familia ISO 27000 (desde 2005), que incorpora la gestión sistemática de los riesgos y la mejora continua. Estas normas están dirigidas a quienes inician, implantan o mantienen la seguridad de la información en una organización, y tres de ellas se complementan entre sí.

La ISO/IEC 27001 establece los requisitos para establecer, implementar, operar, monitorear, analizar críticamente, mantener y mejorar un Sistema de Gestión de Seguridad de la Información (SGSI). El SGSI es el sistema mediante el cual la organización gestiona los riesgos de su información, considerando no solo la tecnología sino también los procesos y las personas: determina qué activos proteger, analiza sus riesgos, selecciona controles y verifica que sean eficaces. Por ello, la seguridad se trata como un proceso permanente integrado a la gestión general y no como una implementación única. Ese proceso sigue el ciclo de mejora continua PHVA (Planificar, Hacer, Verificar, Actuar): se planifica la gestión de la seguridad y de los riesgos, se implementan y operan los controles, se verifica su funcionamiento mediante monitoreo, mediciones, auditorías y revisiones, y se aplican acciones correctivas y de mejora. La norma contempla además el alcance del SGSI, las responsabilidades, la documentación, las auditorías y la revisión por parte de la dirección. Está alineada con la ISO 9001: ambas se basan en un enfoque de sistema de gestión, lo que permite consolidar varios sistemas de la organización en uno solo, optimizar sus procesos y facilitar el tránsito de información entre ellos, aunque cada una conserva su objeto propio (la calidad en la ISO 9001 y la seguridad de la información en la ISO/IEC 27001).

La ISO/IEC 27002 es un código de práctica que orienta sobre la selección, implementación y gestión de los controles, considerando el entorno de riesgos

de cada organización. A diferencia de la 27001, no fija requisitos: ofrece recomendaciones sobre los controles que pueden utilizarse, organizados en áreas que se detallan en 1.14. Por su parte, la ISO 31000 no es una norma de seguridad de la información ni define controles: aporta el marco general de gestión de riesgos con el que se alinean los requisitos de análisis de riesgos del SGSI.

En octubre de 2013 se actualizaron ambas normas (ISO/IEC 27001:2013 e ISO/IEC 27002:2013). La edición 2013 de la 27001 adopta una estructura común a las normas de sistemas de gestión, lo que facilita su integración con otras, y su Anexo A pasa a contar con 114 controles en 14 categorías o dominios, frente a los 133 controles en 11 categorías de la edición 2005. La 27002:2013 alineó con ese Anexo tanto el número de controles como su estructura, y adoptó la terminología de la ISO/IEC 27000.

1.2 ¿Por qué preocuparse por la seguridad?

La información puede existir en distintos formatos (impresa, almacenada electrónicamente, hablada, transmitida por correo convencional o electrónico) y, cualquiera sea el medio, requiere protección adecuada. La sociedad depende de la información almacenada en sistemas informáticos para la toma de decisiones en empresas, entidades de gobierno y otros contextos organizacionales, por lo que su seguridad es fundamental para la supervivencia de las organizaciones.

Los problemas más comunes son cinco. La destrucción de información o de los recursos que la procesan y almacenan afecta directamente la capacidad de operar y genera costos de recuperación. La modificación o distorsión hace que los datos dejen de ser confiables y que las decisiones basadas en ellos sean incorrectas. El robo, la eliminación o la pérdida de información puede interrumpir procesos y hacer perder registros necesarios para decidir. La revelación implica que información restringida llegue a personas no autorizadas, con posibles consecuencias económicas, legales o contractuales. La interrupción de los servicios, causada por fallas técnicas, errores humanos, ataques o problemas de infraestructura, impide que los usuarios utilicen los sistemas que necesitan.

Proteger la información permite garantizar la continuidad del negocio, minimizar el riesgo y maximizar el retorno de la inversión. Hoy es además un factor clave para la competitividad, la rentabilidad, el cumplimiento de los requisitos legales y la imagen de la organización, tanto en el sector público como en el privado. Es también un componente que viabiliza negocios como el gobierno electrónico (e-government) y el comercio electrónico (e-commerce), y una gestión adecuada genera confianza en clientes, proveedores y otras partes interesadas. Para que sea efectiva, debe estar alineada con los objetivos de la organización y ser proporcional a sus riesgos.

1.3 Definiciones

La seguridad de la información es la protección de la información, los sistemas, los recursos y demás activos contra desastres, errores (intencionales o no) y manipulación no autorizada, con el fin de reducir la probabilidad y el impacto de

los incidentes de seguridad. Según la ISO/IEC 27002, protege la información de los diversos tipos de amenazas para garantizar la continuidad del negocio, minimizar los riesgos y maximizar el retorno de la inversión y las oportunidades de negocio. Se logra mediante un conjunto de controles (políticas, procesos, procedimientos, estructuras organizacionales y funciones de hardware y software) que deben establecerse, implementarse, monitorearse, evaluarse y mejorarse continuamente para cumplir los objetivos del negocio y de seguridad de la organización. Es el concepto de mayor alcance: protege la información sin importar dónde o cómo se encuentre y abarca tecnología, procesos y personas. La seguridad informática es una parte de ella y se enfoca en los sistemas y recursos tecnológicos que procesan, almacenan o transmiten la información (equipos, redes, sistemas operativos, aplicaciones y bases de datos). La ciberseguridad pone el énfasis en la protección del entorno digital y de los sistemas interconectados frente a amenazas y ataques.

Los conceptos básicos son los siguientes. Un activo es cualquier elemento que tiene valor para la organización y su negocio: bases de datos, software, equipos, servidores, dispositivos de red, personas, procesos y servicios. Una vulnerabilidad es una debilidad de un activo o grupo de activos que puede ser explotada, por ejemplo por fallas de seguridad o configuraciones incorrectas; por sí sola no causa daño, sino que el problema aparece cuando una amenaza la aprovecha. Una amenaza es cualquier evento que puede explotar una vulnerabilidad y causar daños a un sistema o a la organización (errores humanos, código malicioso, fallas de sistemas, invasiones, desastres naturales, sabotaje, accesos no autorizados); es una causa potencial de un incidente, es decir, aún no ocurrió. Un incidente de seguridad es un evento adverso que compromete o puede comprometer la seguridad, como un ataque de denegación de servicio (DoS), el robo o la fuga de información o el acceso no autorizado. Un ataque es una acción deliberada que compromete la seguridad de la organización al intentar esquivar los controles para explotar vulnerabilidades. El impacto es el resultado evaluado de un evento particular, es decir, el daño sobre los sistemas, la información, los servicios o los objetivos de la organización, y su análisis busca identificar los recursos críticos.

El riesgo es la combinación de la probabilidad de que ocurra un evento (la oportunidad de que la amenaza se materialice) y sus consecuencias para la organización; combina amenazas, vulnerabilidades e impactos y sirve de base para decidir qué medidas implementar. Como método de referencia se calcula $\text{Riesgo} = \text{Impacto} \times \text{Probabilidad}$, con valores de 0 a 5 para cada factor, lo que da un resultado entre 0 y 25.

Estos conceptos se relacionan de la siguiente manera: un activo presenta vulnerabilidades, una amenaza puede explotarlas y esa posibilidad constituye el riesgo, que existe antes de que ocurra cualquier incidente. Si la amenaza se materializa, se produce el incidente y su consecuencia es el impacto. Por eso el análisis de riesgos busca anticiparse al incidente y determinar qué medidas reducen su probabilidad o su impacto.

1.4 Modelos de ataque

Existen cuatro modelos de ataque, que representan qué le ocurre a un activo cuando es objeto de una acción no autorizada y que se asocian cada uno con una propiedad de seguridad. En el flujo normal, la información va de una fuente a un destino; cada ataque altera ese flujo de una manera distinta.

La interrupción se produce cuando un activo se destruye o queda indisponible o inutilizable; es un ataque contra la disponibilidad (por ejemplo, la destrucción de un disco duro). La interceptación ocurre cuando un tercero no autorizado, ya sea una persona o un programa, accede a un activo sin necesariamente alterarlo; es un ataque contra la confidencialidad (por ejemplo, la copia no autorizada de archivos o programas). La modificación se da cuando un tercero no autorizado accede a un activo y altera su contenido, de modo que la información deja de ser correcta; es un ataque contra la integridad (por ejemplo, el cambio de los valores de un archivo de datos). La fabricación ocurre cuando una parte no autorizada inserta objetos falsificados en un activo para que parezcan legítimos; es un ataque contra la autenticidad (por ejemplo, la adición de registros falsos en un archivo).

1.5 Formas de ataque

Los ataques pueden ser pasivos o activos. Los ataques pasivos consisten en escuchar o monitorear las transmisiones para obtener la información transmitida, sin modificar los datos ni afectar el funcionamiento del sistema, como escuchar una conversación telefónica. Por esa razón son difíciles de detectar, ya que no dejan evidencias y el sistema sigue funcionando con normalidad mientras el atacante obtiene información. Sí pueden prevenirse, y la principal medida es la criptografía, que protege el contenido transmitido de modo que, aunque sea interceptado, no pueda leerse directamente.

Los ataques activos, en cambio, implican la modificación de datos, la creación de objetos falsos o la negación de servicio, y tienen propiedades opuestas a las de los pasivos. Son difíciles de prevenir por completo, porque exigirían proteger todas las instalaciones de comunicación y procesamiento durante todo el tiempo. Por eso, además de las medidas preventivas, se apunta a detectarlos y a contar con mecanismos para recuperarse de los perjuicios causados.

1.6 Arquitectura de seguridad

La arquitectura de seguridad propuesta por el modelo Open Systems Interconnection (OSI, Interconexión de Sistemas Abiertos), definida en la norma ISO 7498-2, fija los objetivos y requisitos de seguridad sobre los cuales se definen luego los servicios y mecanismos para enfrentar las amenazas. Son cinco: proteger los datos contra modificaciones no autorizadas (integridad); protegerlos contra pérdida, robo o hurto (principalmente disponibilidad, y también confidencialidad si lo sustraído queda en poder de un tercero); protegerlos contra toda divulgación no autorizada (confidencialidad); asegurar la identidad del remitente correcto de los datos, para que lo recibido provenga realmente de quien debía enviarlo y no de alguien que lo suplanta; y asegurar la identidad del

destinatario correcto, para que la información llegue a quien corresponde y no a una persona o sistema no autorizado. Los dos últimos se relacionan con la autenticidad.

1.7 Servicios de seguridad

Según la ISO 7498-2, los servicios de seguridad son medidas preventivas elegidas para hacer frente a las amenazas identificadas; también se los conoce como principios básicos de seguridad. Cada servicio indica qué propiedad se busca garantizar y se implementa mediante uno o más mecanismos de seguridad, que son los medios técnicos utilizados para lograrlo. Su selección y prioridad dependen de los requisitos de seguridad de la organización y del análisis de los riesgos e impactos probables, y no todos se aplican con la misma prioridad en cualquier organización.

La confidencialidad protege los datos contra el acceso no autorizado, es decir, contra los ataques pasivos, mediante mecanismos como el control de acceso y la encriptación. Se pierde cuando información restringida, por ejemplo la contraseña de un usuario o administrador, queda expuesta a quienes no debían conocerla. La autenticidad garantiza que la comunicación sea auténtica: origen y destino (usuarios, dispositivos o procesos) pueden verificar la identidad de la otra parte y confirmar que es quien dice ser, lo que reduce el riesgo de aceptar información falsa como legítima.

La integridad es la garantía contra los ataques activos, esto es, contra los cambios o remociones no autorizados de los datos, tanto almacenados como transmitidos. Como en estos ataques importa más la detección que la prevención, se distingue entre integridad sin recuperación, que solo detecta e informa la violación, e integridad con recuperación, que además activa un mecanismo para restablecer los datos afectados. Es también un prerrequisito de otros servicios: si se altera de forma no autorizada el sistema de control de acceso de un sistema operativo, se compromete además la confidencialidad de sus archivos.

El no repudio impide que el origen o el destino de una comunicación niegue su participación en ella: quien recibe un mensaje puede demostrar que fue enviado por determinado origen, y viceversa, lo que aporta evidencia sobre quién realizó una comunicación o transacción. La conformidad es el deber de cumplir y hacer cumplir las regulaciones internas y externas aplicables a las actividades de la organización, lo que muestra que la seguridad no depende solo de aspectos técnicos. El control de acceso limita el acceso lógico y físico a los activos mediante los procesos de identificación, autenticación y autorización, para evitar accesos no autorizados; exige además revisar periódicamente los derechos de acceso otorgados a empleados, contratistas y colaboradores. Por último, la disponibilidad asegura que los recursos puedan ser utilizados por las entidades autorizadas siempre que lo soliciten, y protege contra su pérdida o degradación; se pierde, por ejemplo, cuando cae un servidor o una aplicación crítica por una falla interna o externa o por la acción de personas no autorizadas, con o sin

intención maliciosa. Está estrechamente vinculada con la continuidad del negocio.

1.8 Seguridad de la información

La gestión de la seguridad de la información consiste en administrar de forma sistemática las medidas necesarias para proteger los activos frente a los riesgos existentes, e integra tres niveles: la tecnología, que aporta los ajustes técnicos; los procesos, que permiten desarrollar de manera sistemática las actividades de gestión del riesgo; y las personas, que deben conocer sus responsabilidades y colaborar en reducir y controlar los riesgos. Esto incluye a empleados, administradores, directivos, contratistas y socios, y es clave para reducir los riesgos de robo, fraude y uso indebido de los recursos y la información. También deben saber identificar y comunicar los eventos adversos que representen riesgos reales o potenciales, para lo cual se educa, sensibiliza y capacita al personal en las amenazas y en la política de seguridad vigente, reduciendo los errores humanos.

Los cambios tecnológicos y organizacionales (nuevos sistemas, servicios, contratos, sociedades o formas de intercambiar información) pueden generar nuevas vulnerabilidades y riesgos o agravar los existentes. Por eso los cambios deben controlarse y la evaluación de riesgos debe ser periódica, dinámica y sistemática, ya que permite conocer los niveles de riesgo y cómo tratarlos. Paralelamente, la organización debe conocer las leyes que está obligada a cumplir y extraer de ellas sus requisitos de seguridad; a partir de esos requisitos legales y de los resultantes del análisis de riesgos se identifican los controles necesarios, con apoyo en las normas de seguridad, y de ellos se derivan las políticas, normas y procedimientos para aplicarlos. Las medidas resultantes pueden ser preventivas, correctivas o educativas.

La gestión del riesgo comprende las actividades para dirigir y controlar una organización en términos de riesgos: su análisis, evaluación, tratamiento y aceptación (y su comunicación). El tratamiento consiste en seleccionar y aplicar medidas para modificar un riesgo, se realiza después del análisis y la evaluación y busca reducirlo a un nivel aceptable para la organización. Tiene cuatro alternativas: evitar, que aplica medidas preventivas para impedir que la vulnerabilidad sea explotada; transferir, que traslada el riesgo a un tercero, por ejemplo mediante un seguro; mitigar, que aplica medidas de seguridad para reducirlo a un nivel aceptable; y aceptar, que asume sus posibles consecuencias. La elección debe considerar las características de la organización y del riesgo, así como los costos, los objetivos del negocio, los requisitos legales y la privacidad, ya que no todas las medidas son viables.

1.9 Preparando a la organización

Antes de gestionar la seguridad, la organización debe responder una serie de preguntas. Debe determinar qué protege (sus activos), contra qué o quién (las amenazas y quién puede explotarlas) y qué importancia tiene cada recurso, dado que todos participan en algún proceso de negocio, entendido como el conjunto

de acciones y actividades que interactúan de manera lógica y coherente para generar un producto que cumpla los requisitos de calidad y las expectativas del cliente, interno o externo. Debe definir además el grado de protección deseado y el que el negocio exige, cuánto tiempo y cuántos recursos financieros y humanos destinará a la seguridad, con qué recursos cuenta y qué puede lograr con ellos, y qué esperan de la seguridad de la información los directivos, clientes y usuarios.

No todos los activos requieren el mismo nivel de protección: las medidas deben ajustarse a su importancia, a las amenazas y a los posibles impactos, concentrándose en los activos de mayor impacto. La decisión debe equilibrar el costo de prevenir o recuperar un daño con la importancia del activo y las consecuencias de su afectación, y si evitar una amenaza cuesta más que el daño potencial, pueden considerarse otras alternativas de tratamiento. Con estas respuestas se puede avanzar en el establecimiento y la gestión de la seguridad.

1.10 Requisitos de seguridad

Los requisitos de seguridad determinan qué nivel de protección necesita la organización y surgen de tres fuentes principales. La primera es la evaluación y análisis de riesgos, que considera los objetivos y estrategias del negocio para identificar las vulnerabilidades y amenazas sobre los activos, teniendo en cuenta su probabilidad de ocurrencia y su impacto. La segunda es la legislación vigente: los estatutos, reglamentos y cláusulas contractuales que deben cumplir la organización, sus socios, subcontratistas y proveedores. En este punto, la contratación de servicios externos puede exigir cláusulas que definan las responsabilidades del tercero en materia de seguridad, y las medidas implementadas no pueden ignorar la legislación y la privacidad (por ejemplo, el seguimiento o registro de usuarios puede estar limitado por ley). La tercera es el conjunto de principios, objetivos y requisitos de negocio para el procesamiento de datos que la propia organización define para sostener sus operaciones; en ese marco, la política de seguridad y el código de conducta ayudan a establecer responsabilidades y orientar la conducta de las personas.

1.11 Análisis y evaluación de riesgos

La evaluación del riesgo compara el riesgo estimado en el análisis con criterios predefinidos, para determinar su importancia para la organización y el nivel que puede considerarse aceptable según sus necesidades de negocio y de seguridad. Sus resultados permiten priorizar los riesgos según su gravedad, las pérdidas posibles y los costos de prevención o recuperación, y orientar las acciones gerenciales hacia los que tendrían mayores consecuencias. El gasto en controles debe equilibrarse con el impacto que causarían las posibles fallas de seguridad, y como la organización y su entorno cambian, el análisis y la evaluación deben repetirse periódicamente.

1.12 Selección de controles

Una vez identificados los requisitos de seguridad, realizado el análisis y la evaluación de riesgos y decidido su tratamiento, se seleccionan e implementan

los controles adecuados. Un control, también llamado contramedida, es una medida o conjunto de medidas adoptadas para hacer frente a las vulnerabilidades y reducir el riesgo de incidentes de seguridad. Es cualquier mecanismo útil para gestionar riesgos (políticas, procedimientos, directrices, prácticas o estructuras organizativas) y puede ser de carácter administrativo, técnico, de gestión o legal. Los controles administrativos se relacionan con la organización, las políticas, los procedimientos y las responsabilidades; los técnicos usan mecanismos tecnológicos, como el control de acceso, la encriptación, la autenticación y la protección de sistemas y comunicaciones; los de gestión abarcan el análisis y la evaluación de riesgos, la priorización, la revisión de las medidas y la mejora de su eficacia; y los legales son las obligaciones que impone la normativa. Según su función, un control puede impedir que se explote una vulnerabilidad, detectar una actividad no autorizada o permitir la recuperación tras un incidente.

Los controles se seleccionan a partir de normas preestablecidas (por ejemplo, las ISO/IEC 27001 e ISO/IEC 27002) o de un conjunto propio de la organización, y siempre deben ajustarse a las leyes y regulaciones nacionales e internacionales aplicables, en especial cuando implican registrar o seguir la actividad de las personas. No existe una combinación única de controles válida para todas las organizaciones, porque los riesgos varían según el contexto, y una medida técnicamente adecuada no es viable si contradice una obligación legal o afecta derechos protegidos.

Son ejemplos de controles las barreras, puertas, carteles de prohibición y torniquetes; las tarjetas de control de visitantes y el circuito cerrado de televisión; las contraseñas, cerraduras y controles biométricos; las políticas de seguridad, el manual de responsabilidades y el entrenamiento; y el antivirus, las copias de seguridad, la autenticación fuerte, los planes de contingencia y el control de acceso lógico. El control biométrico usa características físicas o de comportamiento de las personas para identificarlas o verificar su acceso a recursos como computadores, teléfonos, redes, aplicaciones o bases de datos.

1.13 Los controles de seguridad de la información

Algunos controles se consideran "primeros pasos" para la seguridad de la información, por derivar de requisitos legales o de mejores prácticas. Desde el punto de vista legal, los controles fundamentales, que dependen de la legislación vigente, son la protección de datos y privacidad de la información personal, la protección de los registros de la organización y los derechos de propiedad intelectual. Entre las buenas prácticas se cuentan documentar la política de seguridad, asignar responsabilidades, sensibilizar, educar y capacitar, asegurar el procesamiento correcto en las aplicaciones, gestionar las vulnerabilidades técnicas, gestionar la continuidad del negocio y gestionar los incidentes de seguridad.

Estos controles son un punto de partida y no sustituyen la selección basada en el análisis y evaluación de los riesgos específicos de cada organización. Del mismo modo, la política de seguridad no debe definirse en términos generales:

cada organización debe analizarse caso por caso para identificar sus necesidades y desarrollar una política adecuada, que asigne derechos y responsabilidades a quienes se vinculan con la información y los recursos informáticos. Cualquier evento que viole la política se considera un incidente de seguridad.

1.14 Elementos relevantes para la seguridad de la información

La gestión de la seguridad de la información promueve la adopción de políticas, procedimientos, directrices y otros elementos cuyo alcance debe abarcar la gestión del riesgo con criterio de costo/beneficio para la organización, es decir, con controles razonables respecto de los riesgos tratados y de la importancia de lo protegido. Los elementos relevantes son los siguientes.

La política de seguridad de la información establece los lineamientos, responsabilidades y objetivos de protección, en relación con las necesidades y los requisitos legales, contractuales y regulatorios de la organización. La seguridad organizacional define cómo se integra la seguridad en la estructura de la organización. La gestión de activos identifica y protege los recursos con valor para el negocio. La seguridad de los recursos humanos cubre todo el ciclo de relación de las personas con la organización (antes, durante y al finalizar o cambiar la relación laboral), incluyendo responsabilidades, capacitación, procedimientos disciplinarios, devolución de activos y retirada de derechos de acceso. La seguridad física y del ambiente protege las instalaciones y los equipos mediante el perímetro físico, las zonas seguras y las medidas que garantizan su funcionamiento continuo, como el suministro de energía y el mantenimiento. La gestión de las operaciones y comunicaciones abarca los procedimientos operacionales, las copias de seguridad, la gestión de redes, la manipulación de medios, el intercambio de información y el monitoreo. El control de acceso garantiza que los recursos sean utilizados solo por usuarios autorizados, e incluye el registro de usuarios, la gestión de privilegios y contraseñas, la revisión de derechos y la seguridad de la computación móvil y el trabajo remoto. La adquisición, desarrollo y mantenimiento de sistemas incorpora la seguridad desde los requisitos de los nuevos sistemas y la mantiene durante su desarrollo y funcionamiento. La gestión de incidentes de seguridad establece cómo reportar eventos y debilidades, determinar responsabilidades, responder, aprender de lo ocurrido y recolectar evidencia conforme a la legislación. La gestión de la continuidad del negocio mantiene las actividades de la organización ante desastres o interrupciones mediante planes de contingencia y continuidad y la planificación de la recuperación de desastres.

1.15 Actividades relacionadas

Además de los elementos anteriores, la gestión de la seguridad comprende cuatro actividades. La gestión de la seguridad de los sistemas abarca todos los aspectos de la seguridad de los sistemas de la organización, como la administración de la política de seguridad y los procedimientos de recuperación de desastres, y exige mantenerse actualizado sobre los problemas, riesgos y soluciones más recientes. La gestión de los servicios de seguridad incluye la

selección de los mecanismos más adecuados para atenderlos, y la gestión de los mecanismos de seguridad se ocupa de administrar los disponibles para cumplir los requisitos de la organización.

La gestión de la auditoría de seguridad comprende la revisión y verificación de registros y eventos de seguridad, con el fin de evaluar si los controles son adecuados, verificar el cumplimiento de la política de seguridad, detectar situaciones que requieran cambios y recomendar las modificaciones necesarias. Esta revisión aporta evidencias del funcionamiento de los controles, permite detectar fallas, brechas o incidentes y comprobar que las actividades delegadas se realicen como se estableció. La evaluación de los controles determina si las medidas alcanzan los objetivos de seguridad y siguen siendo adecuadas frente a los cambios en la organización, la tecnología, los procesos, las amenazas y los requisitos legales; ante deficiencias se definen acciones correctivas o preventivas, de modo que la mejora de los controles constituye un proceso continuo.

1.16 Factores críticos para el éxito de la seguridad de la información

El éxito de la seguridad de la información en una organización depende de nueve factores:

1. Primero, la política, los objetivos y las prácticas de seguridad deben reflejar los objetivos de negocio.
2. Segundo, el enfoque y la estructura adoptados para ejecutar, mantener, monitorear y mejorar la seguridad deben ser compatibles con la cultura de la organización.
3. Tercero, todos los niveles gerenciales deben estar comprometidos y apoyar la seguridad.
4. Cuarto, los requisitos de seguridad, el análisis y evaluación de riesgos y la gestión del riesgo deben ser bien entendidos en detalle.
5. Quinto, la seguridad debe darse a conocer eficientemente a todas las entidades de la organización (presidentes, directores, gerentes, empleados, contratistas), y las directrices, políticas y normas deben distribuirse y comunicarse a todas las partes involucradas.
6. Sexto, deben proveerse los recursos financieros para la gestión de la seguridad.
7. Séptimo, debe brindarse sensibilización, entrenamiento y educación adecuados.
8. Octavo, debe establecerse un proceso eficaz de gestión de incidentes.
9. Noveno, debe implementarse un sistema de medición y evaluación de la eficacia de la gestión de seguridad que permita proponer mejoras.

Capítulo 2 — Código de buenas prácticas / NTC-ISO/IEC 27002

2.1 – Estructura de la norma

La NTC-ISO/IEC 27002 está planteada como una guía práctica para desarrollar y aplicar procedimientos y controles de seguridad de la información dentro de una organización. Su finalidad es proporcionar un código de buenas prácticas para la gestión de la seguridad, indicando distintos aspectos que deben ser considerados y controles que pueden seleccionarse, relacionarse y combinarse de acuerdo con las necesidades de la organización.

La norma está organizada en capítulos numerados del 0 al 15. Los capítulos 0 a 4 constituyen la parte introductoria: presentan la introducción, el objetivo de la norma, los términos y definiciones, la estructura y el análisis/evaluación y tratamiento de riesgos. A partir del capítulo 5, la norma denomina a cada capítulo como sección, y se presentan once secciones específicas dedicadas a los controles de seguridad de la información.

2.2 – Sección 4: Análisis/evaluación y tratamiento de los riesgos

La Sección 4, Análisis/evaluación y tratamiento de los riesgos, pertenece todavía a la parte introductoria de la norma. Su propósito es presentar la importancia del análisis de riesgos para la organización y proporcionar indicaciones generales sobre la manera en que debe realizarse.

El análisis y la evaluación de riesgos permiten identificar los riesgos de seguridad de la información y determinar cuáles requieren atención. Para ello se consideran aspectos como las amenazas, las vulnerabilidades, los posibles impactos y la probabilidad de ocurrencia. La actividad debe realizarse de manera sistemática, mediante métodos concretos y periódicamente, especialmente cuando cambian los requisitos de seguridad, los activos, las vulnerabilidades o los objetivos del negocio.

El tratamiento de riesgos consiste posteriormente en seleccionar y aplicar medidas que permitan modificar los riesgos identificados. Las decisiones deben considerar el nivel de riesgo aceptable para la organización y la importancia de los activos para la continuidad del negocio. De esta manera, el análisis de riesgos constituye una base para determinar qué medidas de seguridad resultan apropiadas y dónde deben concentrarse los esfuerzos de protección.

2.3 – Sección 5: Política de seguridad

La Sección 5, Política de seguridad, establece los controles destinados a proporcionar orientación y apoyo de gestión para la seguridad de la información mediante una política clara y objetiva, alineada con los objetivos del negocio. La sección contiene la Categoría 5.1 - Política de seguridad de la información, que posee dos controles.

La Categoría 5.1, Política de seguridad de la información, tiene como objetivo establecer la orientación general de seguridad que debe seguir la organización. La política debe establecer las directrices, responsabilidades y objetivos relacionados con la protección de la información y servir como referencia para los controles que se implementen.

El Control 5.1.1, Documento de la política de seguridad de la información, establece la necesidad de disponer de un documento que contenga los elementos relevantes de la política. Entre las directrices se destaca la importancia de definir adecuadamente su contenido y de comunicarlo a las personas correspondientes dentro de la organización.

El Control 5.1.2, Análisis crítico de la política de seguridad de la información, establece que la política debe ser sometida a un análisis crítico por parte de la dirección de la organización. Esto permite comprobar que continúa siendo adecuada y que mantiene correspondencia con las necesidades de seguridad existentes.

2.4 – Sección 6: Organización de la seguridad de la información

La Sección 6, Organización de la seguridad de la información, tiene como objetivo establecer controles para gestionar la seguridad dentro de la organización y mantener protegidos los recursos de procesamiento de información cuando estos se encuentran disponibles para partes externas. Se consideran partes externas, entre otros, vendedores, proveedores, agencias gubernamentales, contratistas, proveedores de servicios temporales y clientes.

Categoría 6.1, Infraestructura de seguridad de la información. Esta categoría organiza los controles relacionados con la estructura funcional de la seguridad de la información.

- Control 6.1.1, Compromiso de la dirección con la seguridad de la información: establece el compromiso de la dirección con la seguridad de la información y su apoyo a las actividades necesarias para gestionarla.
- Control 6.1.2, Coordinación de la seguridad de la información: establece la coordinación de las actividades de seguridad dentro de la organización, evitando que se gestionen de manera aislada.
- Control 6.1.3, Asignación de responsabilidades para la seguridad de la información: determina quiénes son responsables de las distintas actividades relacionadas con la seguridad.
- Control 6.1.4, Proceso de autorización para los recursos de procesamiento de información: establece la necesidad de controlar y autorizar formalmente el uso de los recursos informáticos.
- Control 6.1.5, Acuerdos de confidencialidad: establece acuerdos destinados a proteger la información que debe mantenerse confidencial.
- Control 6.1.6, Contacto con las autoridades: contempla el establecimiento de contactos adecuados con las autoridades correspondientes.

- Control 6.1.7, Contacto con grupos de interés especial: establece contactos con grupos, asociaciones u organismos especializados que puedan aportar información relevante para la seguridad.
- Control 6.1.8, Revisión independiente de la seguridad de la información: establece la revisión periódica de la seguridad para comprobar que continúa siendo adecuada y corregirla cuando sea necesario. El propio capítulo destaca expresamente este control y señala que la seguridad debe analizarse, revisarse y corregirse periódicamente.

Categoría 6.2, Partes externas. Esta categoría trata los controles necesarios cuando personas u organizaciones externas necesitan acceder a los recursos de procesamiento de información de la organización. El objetivo es que esa relación con terceros contemple las condiciones de seguridad correspondientes y que las partes externas involucradas sean identificadas.

- Control 6.2.1, Identificación de los riesgos relacionados con las partes externas: determina los riesgos que pueden surgir por el acceso de terceros a la información o a los recursos.
- Control 6.2.2, Tratamiento de la seguridad en los acuerdos con terceros: establece las condiciones de seguridad que deben contemplarse en los acuerdos con las partes externas.
- Control 6.2.3, Requisitos de seguridad en los acuerdos con terceros: especifica los requisitos de seguridad que deben establecerse cuando terceros acceden a recursos o información.
- Control 6.2.4, Requisitos de seguridad en la cadena de suministro de tecnologías de información y comunicaciones: contempla las condiciones de seguridad relacionadas con los servicios y recursos tecnológicos proporcionados por terceros.

2.5 – Sección 7: Gestión de activos

La Sección 7, Gestión de activos, establece controles destinados a proteger adecuadamente los activos de la organización y a proporcionar a la información un nivel de seguridad apropiado. Se divide en dos categorías:

Categoría 7.1, Responsabilidad de los activos. Tiene como objetivo alcanzar y mantener una protección adecuada de los activos de la organización. Los controles establecen responsabilidades relacionadas con la identificación, propiedad y utilización de dichos activos.

- Control 7.1.1, Inventario de activos: mantiene un inventario de los activos importantes para la organización.
- Control 7.1.2, Propiedad de los activos: establece quién es responsable de cada activo.
- Control 7.1.3, Uso aceptable de los activos: determina las condiciones y reglas para el uso adecuado de los activos.

Categoría 7.2, Clasificación de la información. Establece controles para clasificar la información y asignarle un nivel de seguridad adecuado.

- Control 7.2.1, Directrices de clasificación: establece la clasificación de la información según sus necesidades de protección.
- Control 7.2.2, Etiquetado y manejo de la información: establece cómo debe identificarse y manipularse la información de acuerdo con su clasificación.
- Control 7.2.3, Manejo de activos: establece procedimientos para el manejo de los activos de información de acuerdo con la clasificación correspondiente.

2.6 – Sección 8: Seguridad de los recursos humanos

La Sección 8, Seguridad de los recursos humanos, establece los controles de seguridad de la información aplicables durante el ciclo de vida de la relación de los profesionales con la organización. Se divide en tres categorías:

Categoría 8.1, Antes de la contratación. Comprende los controles relacionados con el proceso de selección y las condiciones de los contratos de los recursos humanos.

- Control 8.1.1, Roles y responsabilidades: establece las responsabilidades de seguridad correspondientes a los puestos.
- Control 8.1.2, Selección: considera los requisitos de seguridad durante el proceso de selección.
- Control 8.1.3, Términos y condiciones de empleo: establece las obligaciones y responsabilidades de seguridad que deben formar parte de las condiciones de contratación.

Categoría 8.2, Durante la contratación. Comprende los controles aplicables mientras los recursos humanos prestan sus servicios. Incluye las responsabilidades, la capacitación en seguridad de la información y los procedimientos disciplinarios ante incumplimientos.

- Control 8.2.1, Responsabilidades de la dirección: establece que la dirección debe garantizar que los empleados conozcan y cumplan sus responsabilidades de seguridad.
- Control 8.2.2, Sensibilización, educación y formación en seguridad de la información: establece la capacitación y concientización del personal respecto de la seguridad.
- Control 8.2.3, Proceso disciplinario: establece medidas frente al incumplimiento de las políticas y procedimientos de seguridad.

Categoría 8.3, La finalización o cambio de la contratación. Comprende los controles aplicables cuando una persona finaliza su relación con la organización o cambia de área, cargo o función. Se destacan especialmente la devolución de activos y la retirada de derechos de acceso.

- Control 8.3.1, Responsabilidades de terminación: establece las responsabilidades de seguridad que continúan o deben ejecutarse cuando termina o cambia la relación laboral.
- Control 8.3.2, Devolución de activos: establece la devolución de los activos de la organización que se encontraban bajo responsabilidad de la persona.
- Control 8.3.3, Retirada de derechos de acceso: establece la eliminación o modificación de los derechos de acceso cuando finaliza o cambia la relación con la organización.

2.7 – Sección 9: Seguridad física y del entorno

La Sección 9, Seguridad física y del entorno, trata la protección física de las instalaciones y de los equipos utilizados para el procesamiento de la información. Está dividida en dos categorías:

Categoría 9.1, Áreas seguras. Comprende los controles relacionados con el acceso físico a las instalaciones. Incluye el establecimiento de perímetros físicos, controles de entrada, zonas seguras, áreas de acceso público y zonas destinadas a la entrega de materiales.

- Control 9.1.1, Perímetro de seguridad física: establece los límites físicos que deben proteger las instalaciones.
- Control 9.1.2, Controles de entrada física: controla y restringe el ingreso físico a las áreas protegidas.
- Control 9.1.3, Seguridad de oficinas, despachos e instalaciones: establece medidas para proteger los espacios físicos de la organización.
- Control 9.1.4, Protección contra amenazas externas y ambientales: contempla medidas frente a amenazas provenientes del exterior o del ambiente.
- Control 9.1.5, Trabajo en áreas seguras: establece medidas para quienes desarrollan actividades dentro de áreas que requieren protección especial.
- Control 9.1.6, Áreas de acceso público, carga y descarga: controla las zonas donde existe acceso público o se reciben y entregan materiales.

Categoría 9.2, Seguridad de los equipos. Comprende los controles destinados a proteger físicamente los equipos y garantizar que puedan funcionar sin interrupciones. Incluye cuestiones como la instalación, suministro de energía, climatización, mantenimiento, reutilización y eliminación de activos.

- Control 9.2.1, Ubicación y protección de los equipos: establece medidas para proteger los equipos frente a riesgos físicos y ambientales.
- Control 9.2.2, Servicios de soporte: contempla la protección de servicios necesarios para el funcionamiento de los equipos, como energía y climatización.
- Control 9.2.3, Seguridad del cableado: protege el cableado eléctrico y de comunicaciones frente a daños, interferencias o accesos indebidos.

- Control 9.2.4, Mantenimiento de los equipos: establece condiciones para realizar mantenimiento de manera segura y adecuada.
- Control 9.2.5, Seguridad de los equipos fuera de las instalaciones: contempla la protección de los equipos cuando se utilizan fuera de las instalaciones de la organización.
- Control 9.2.6, Seguridad en la reutilización o eliminación de equipos: establece medidas para evitar que información sensible permanezca en equipos que serán reutilizados o eliminados.
- Control 9.2.7, Retiro de activos: controla el retiro físico de equipos y otros activos de las instalaciones.

2.8 – Sección 10: Gestión de operaciones y comunicaciones

La Sección 10, Gestión de operaciones y comunicaciones, comprende los controles relacionados con las operaciones de los servicios tecnológicos de la organización. Es la sección más extensa y está formada por diez categorías principales, cuyos controles deben aplicarse en las actividades cotidianas de operación y comunicación de las Tecnologías de la Información y las Comunicaciones.

2.8.1 Categoría 10.1: Procedimientos y responsabilidades operacionales

La Categoría 10.1, Procedimientos y responsabilidades operacionales, tiene como objetivo garantizar el funcionamiento seguro y correcto de los recursos informáticos.

- Control 10.1.1 – Documentos de los procedimientos de operación: Establece la necesidad de documentar los procedimientos de operación, de manera que las actividades puedan realizarse siguiendo pautas definidas.
- Control 10.1.2 – Gestión del cambio: Define cómo deben controlarse las modificaciones y alteraciones realizadas sobre los sistemas y recursos informáticos, evitando que los cambios introduzcan riesgos innecesarios.
- Control 10.1.3 – Distribución de funciones: Busca reducir las oportunidades de uso indebido mediante la separación de las funciones que intervienen en las operaciones.
- Control 10.1.4 – Separación de recursos de desarrollo, prueba y producción: Establece la separación de estos ambientes para reducir el riesgo de accesos o modificaciones no autorizadas sobre los sistemas que se encuentran en producción.

2.8.2 Categoría 10.2: Gestión de servicios externalizados

La Categoría 10.2, Gestión de servicios externalizados, tiene como objetivo mantener un nivel adecuado de seguridad y garantizar que la entrega de servicios externos se realice de acuerdo con los acuerdos establecidos.

- Control 10.2.1 – Entrega de servicios: Busca garantizar que los controles de seguridad acordados con terceros sean efectivamente cumplidos durante la prestación del servicio.

- Control 10.2.2 – Monitoreo y análisis de los servicios de terceros: Establece la necesidad de realizar un seguimiento y un análisis crítico periódico de los servicios proporcionados por terceros.
- Control 10.2.3 – Gestión del cambio para los servicios externalizados: Establece que los cambios realizados en servicios externalizados deben gestionarse considerando la importancia y el estado crítico de los sistemas y procesos involucrados.

2.8.3 Categoría 10.3: Planeación y aceptación de los sistemas

La Categoría 10.3, Planeación y aceptación de los sistemas, tiene como objetivo reducir al mínimo el riesgo de fallas en los sistemas mediante una adecuada planificación y la realización de pruebas antes de su incorporación.

- Control 10.3.1 – Gestión de capacidad: Establece el monitoreo y la sincronización de los recursos disponibles con las proyecciones de capacidad futura, con el propósito de asegurar el rendimiento requerido.
- Control 10.3.2 – Aceptación de sistemas: Recomienda realizar pruebas de aceptación sobre los nuevos sistemas y sus actualizaciones antes de incorporarlos a la operación.

2.8.4 Categoría 10.4: Protección contra códigos maliciosos y móviles

La Categoría 10.4, Protección contra códigos maliciosos y móviles, tiene como objetivo proteger la integridad del software y de la información frente a este tipo de códigos.

- Control 10.4.1 – Controles contra código malicioso: Establece procedimientos para implementar controles destinados a la detección, prevención y recuperación frente al código malicioso.
- Control 10.4.2 – Controles contra códigos móviles: Establece directrices para utilizar código móvil de manera segura.

2.8.5 Categoría 10.5: Copias de seguridad de información

La Categoría 10.5, Copias de seguridad de información, tiene como objetivo mantener la integridad y disponibilidad de la información mediante la realización de copias de seguridad.

- Control 10.5.1 – Copias de seguridad de la información y del software: Establece que deben realizarse copias de seguridad tanto de la información como de los programas de software, y que estas copias deben ser probadas regularmente para comprobar su utilidad.

2.8.6 Categoría 10.6: Gestión de seguridad de la red

La Categoría 10.6, Gestión de seguridad de la red, tiene como objetivo garantizar la protección de la información que circula por las redes y de la infraestructura que las soporta.

- Control 10.6.1 – Control de redes: Establece la necesidad de una adecuada gestión y control de las redes, incluyendo la protección de la información en tránsito.

- Control 10.6.2 – Seguridad de los servicios de red: Establece que los niveles de servicio de red deben identificarse e incluirse en los acuerdos de nivel de servicio.

2.8.7 Categoría 10.7: Manipulación de medios

La Categoría 10.7, Manipulación de medios, reúne controles destinados a evitar la divulgación no autorizada, modificación, supresión o destrucción de información almacenada en medios.

- Control 10.7.1 – Gestión de medios removibles: Establece la necesidad de aplicar controles para gestionar adecuadamente los medios removibles.
- Control 10.7.2 – Eliminación de medios: Define las medidas que deben considerarse para realizar correctamente la eliminación de los medios.
- Control 10.7.3 – Procedimientos para el manejo de la información: Establece controles para el manejo y almacenamiento de la información, buscando evitar su divulgación no autorizada.
- Control 10.7.4 – Seguridad de la documentación del sistema: Establece medidas destinadas a proteger la documentación correspondiente a los sistemas.

2.8.8 Categoría 10.8: Intercambio de información

La Categoría 10.8, Intercambio de información, tiene como objetivo mantener la seguridad durante el intercambio de información tanto dentro de la organización como con entidades externas.

- Control 10.8.1 – Políticas y procedimientos para el intercambio de información: Establece la necesidad de contar con políticas y procedimientos destinados a proteger el intercambio de información.
- Control 10.8.2 – Acuerdos de intercambio de información: Establece la necesidad de formalizar acuerdos para el intercambio de información.
- Control 10.8.3 – Medios en tránsito: Recomendación proteger los medios durante su transporte frente al uso indebido o al acceso no autorizado.
- Control 10.8.4 – Mensajes electrónicos: Establece que los mensajes electrónicos deben contar con una protección adecuada.
- Control 10.8.5 – Sistema de información del negocio: Recomendación establecer políticas y procedimientos destinados a proteger la información presente en las interconexiones entre sistemas.

2.8.9 Categoría 10.9: Servicios de comercio electrónico

La Categoría 10.9, Servicios de comercio electrónico, tiene como objetivo garantizar la seguridad durante la utilización de los servicios de comercio electrónico.

- Control 10.9.1 – Comercio electrónico: Establece medidas para proteger la información involucrada en el comercio electrónico frente a actividades fraudulentas.

- Control 10.9.2 – Transacciones en línea: Busca proteger la información utilizada en las transacciones en línea y prevenir problemas como la transmisión incompleta.
- Control 10.9.3 – Información disponible al público: Recomendamos asegurar la integridad de la información que se proporciona mediante sistemas de acceso público.

2.8.10 Categoría 10.10: Monitoreo

La Categoría 10.10, Monitoreo, tiene como objetivo detectar actividades no autorizadas relacionadas con el procesamiento de información.

- Control 10.10.1 – Registros de auditoría: Establece que los registros de auditoría de los eventos de seguridad deben generarse y conservarse durante un período de tiempo acordado.
- Control 10.10.2 – Monitoreo del uso del sistema: Establece procedimientos para supervisar el uso de los recursos destinados al procesamiento de información.
- Control 10.10.3 – Protección de la información de los registros (log): Establece que los registros deben protegerse frente a modificaciones no autorizadas y problemas operacionales.
- Control 10.10.4 – Registros (log) de administrador y operador: Recomendamos registrar las actividades realizadas por los administradores y operadores de los sistemas.
- Control 10.10.5 – Registros (logs) de las fallas: Establece que las fallas deben registrarse y analizarse.
- Control 10.10.6 – Sincronización de relojes: Establece que los sistemas relevantes deben mantener sus relojes sincronizados.

2.9 – Sección 11: Control de acceso

La Sección 11, Control de acceso, comprende los controles relacionados con el acceso lógico a los recursos de información. A diferencia de la seguridad física abordada anteriormente, se concentra en aspectos como los privilegios de acceso, las contraseñas, el acceso a las redes, los sistemas operativos y las aplicaciones.

2.9.1 Categoría 11.1: Requisitos de negocio para el control de acceso

La Categoría 11.1, Requisitos de negocio para el control de acceso, tiene como objetivo controlar el acceso a la información mediante una política que establezca los criterios que deben aplicarse.

- Control 11.1.1 – Política de control de acceso: Establece la necesidad de contar con una política de control de acceso formalmente establecida y sometida a análisis crítico, de manera que los accesos a los recursos de información respondan a criterios definidos.

2.9.2 Categoría 11.2: Gestión de acceso de usuario

La Categoría 11.2, Gestión de acceso de usuario, tiene como objetivo garantizar que solamente los usuarios autorizados puedan acceder a los recursos y evitar accesos no autorizados.

- Control 11.2.1 – Registro de usuario: Establece la conveniencia de contar con un procedimiento formal para registrar nuevos usuarios y cancelar sus cuentas cuando corresponda.
- Control 11.2.2 – Gestión de privilegios: Establece que la concesión y utilización de privilegios deben estar restringidas y controladas, evitando que los usuarios dispongan de permisos superiores a los necesarios.
- Control 11.2.3 – Gestión de contraseña: Establece que la concesión de contraseñas debe encontrarse bajo control, evitando una administración informal o sin mecanismos definidos.
- Control 11.2.4 – Análisis crítico de los derechos de acceso de usuario: Establece la conveniencia de que el administrador realice revisiones periódicas de los derechos de acceso asignados a los usuarios.

2.9.3 Categoría 11.3: Responsabilidades de los usuarios

La Categoría 11.3, Responsabilidades de los usuarios, tiene como objetivo prevenir accesos no autorizados y evitar la afectación o el robo de recursos mediante prácticas seguras por parte de los usuarios.

- Control 11.3.1 – Uso de contraseñas: Establece la necesidad de que los usuarios sigan buenas prácticas en la selección y utilización de sus contraseñas.
- Control 11.3.2 – Equipo del usuario desatendido: Destaca la necesidad de proporcionar una protección adecuada a los equipos cuando permanecen sin supervisión.
- Control 11.3.3 – Política de escritorio limpio y pantalla limpia: Recomendamos adoptar medidas para evitar que documentos, medios o información permanezcan expuestos sobre los escritorios o en las pantallas cuando no deberían estar disponibles.

2.9.4 Categoría 11.4: Control de acceso a redes

La Categoría 11.4, Control de acceso a redes, tiene como objetivo prevenir el acceso no autorizado a los servicios de red.

- Control 11.4.1 – Política de uso de los servicios de red: Establece que los usuarios deben recibir acceso únicamente a los servicios de red que se encuentren autorizados para su utilización.
- Control 11.4.2 – Autenticación de usuarios para conexiones externas: Recomendamos utilizar métodos adecuados para controlar el acceso de los usuarios remotos.
- Control 11.4.3 – Identificación de los equipos en las redes: Recomendamos permitir la identificación automática de los equipos conectados a las redes.

- Control 11.4.4 – Protección y configuración de puertos de diagnóstico remoto: Recomienda controlar el acceso físico y lógico a los puertos utilizados para diagnóstico y configuración.
- Control 11.4.5 – Separación en las redes: Recomienda separar usuarios y sistemas dentro de las redes cuando resulte necesario para mantener el control de acceso.
- Control 11.4.6 – Control de conexión de red: Recomienda restringir la capacidad de los usuarios para establecer conexiones con la red de acuerdo con las necesidades definidas.
- Control 11.4.7 – Control de enrutamiento de la red: Recomienda implementar controles de enrutamiento para garantizar que las conexiones y los flujos de información no infrinjan la política de control de acceso.

2.9.5 Categoría 11.5: Control de acceso al sistema operativo

La Categoría 11.5, Control de acceso al sistema operativo, tiene como objetivo prevenir el acceso no autorizado a los sistemas operativos.

- Control 11.5.1 – Procedimientos seguros para la entrada al sistema (log-on): Establece la conveniencia de controlar el acceso mediante un procedimiento seguro de inicio de sesión.
- Control 11.5.2 – Identificación y autenticación de usuarios: Recomienda que cada usuario posea un identificador único y que se utilice una técnica adecuada para validar su identidad.
- Control 11.5.3 – Sistema de gestión de contraseñas: Recomienda que los sistemas utilizados para administrar contraseñas sean interactivos y permitan una gestión controlada.
- Control 11.5.4 – Uso de las utilidades del sistema: Establece que las utilidades del sistema deben tener un uso restringido y controlado.
- Control 11.5.5 – Tiempo de inactividad de la sesión: Establece la necesidad de suspender las sesiones que permanecen inactivas.
- Control 11.5.6 – Limitación del tiempo de conexión: Permite establecer restricciones sobre los períodos durante los cuales pueden mantenerse las conexiones.

2.9.6 Categoría 11.6: Control de acceso a las aplicaciones y a la información

La Categoría 11.6, Control de acceso a las aplicaciones y a la información, tiene como objetivo prevenir el acceso no autorizado a la información contenida en los sistemas de aplicación.

- Control 11.6.1 – Restricción de acceso a la información: Establece que el acceso a la información y a las funciones de los sistemas de aplicación por parte de usuarios y personal de soporte debe estar restringido.
- Control 11.6.2 – Aislamiento de sistemas sensibles: Recomienda que los sistemas que contienen información sensible dispongan de un ambiente informático aislado.

2.9.7 Categoría 11.7: Computación móvil y trabajo remoto

La Categoría 11.7, Computación móvil y trabajo remoto, tiene como objetivo garantizar la seguridad de la información cuando se utilizan recursos de computación móvil y se realizan actividades de trabajo remoto.

- Control 11.7.1 – Computación y comunicación móvil: Recomendación adoptar políticas y medidas destinadas a reducir los riesgos derivados del uso de recursos informáticos y de comunicaciones móviles.
- Control 11.7.2 – Trabajo remoto: Recomendación elaborar e implementar políticas, planes y procedimientos específicos para realizar actividades de trabajo remoto de forma segura.

2.10 – Sección 12: Adquisición, desarrollo y mantenimiento de sistemas de información

La Sección 12, Adquisición, desarrollo y mantenimiento de sistemas de información, comprende los controles relacionados con la adquisición, el desarrollo y el mantenimiento de las actividades de software. Su objetivo es incorporar la seguridad de la información en las aplicaciones de la organización. La sección está formada por seis categorías principales de seguridad**.

2.10.1 Categoría 12.1: Requisitos de seguridad de sistemas de información

La Categoría 12.1, Requisitos de seguridad de sistemas de información, tiene como objetivo garantizar que la seguridad constituya una parte integrante de los sistemas de información.

- Control 12.1.1 – Análisis y especificación de requisitos de seguridad: Establece que los controles de seguridad deben definirse dentro de las especificaciones de requisitos correspondientes a los nuevos sistemas.

2.10.2 Categoría 12.2: Procesamiento correcto en las aplicaciones

La Categoría 12.2, Procesamiento correcto en las aplicaciones, tiene como objetivo prevenir errores, pérdidas, modificaciones no autorizadas o usos indebidos de la información durante su procesamiento.

- Control 12.2.1 – Validación de datos de entrada: Establece que los datos ingresados en las aplicaciones deben validarse para asegurar que sean correctos y adecuados.
- Control 12.2.2 – Control de procesamiento interno: Recomendación comprobar que las aplicaciones incorporen mecanismos de validación capaces de detectar la corrupción de los datos durante su procesamiento.
- Control 12.2.3 – Integridad de mensajes: Establece requisitos destinados a garantizar la autenticidad y proteger la integridad de los mensajes.
- Control 12.2.4 – Validación de datos de salida: Recomendación validar los datos generados por las aplicaciones para garantizar que el procesamiento haya sido correcto.

2.10.3 Categoría 12.3: Controles criptográficos

La Categoría 12.3, Controles criptográficos, tiene como objetivo proteger la confidencialidad, autenticidad o integridad de la información mediante mecanismos criptográficos.

- Control 12.3.1 – Política sobre el uso de controles criptográficos: Recomienda desarrollar e implementar una política que establezca cómo deben utilizarse los controles criptográficos dentro de la organización.
- Control 12.3.2 – Gestión de claves: Establece la conveniencia de implementar un proceso de gestión de claves que permita respaldar adecuadamente el uso de las técnicas criptográficas.

2.10.4 Categoría 12.4: Seguridad de los archivos del sistema

La Categoría 12.4, Seguridad de los archivos del sistema, tiene como objetivo garantizar la protección de los archivos asociados a los sistemas.

- Control 12.4.1 – Control de software operativo: Establece la necesidad de implementar procedimientos para controlar la instalación de software en los sistemas operativos.
- Control 12.4.2 – Protección de datos para la prueba del sistema: Recomienda que los datos utilizados durante las pruebas sean seleccionados cuidadosamente, protegidos y controlados.
- Control 12.4.3 – Controlar el acceso al código fuente del programa: Establece que el acceso al código fuente debe encontrarse restringido.

2.10.5 Categoría 12.5: Seguridad en los procesos de desarrollo y soporte

La Categoría 12.5, Seguridad en los procesos de desarrollo y soporte, tiene como objetivo mantener la seguridad de los sistemas de información y las aplicaciones durante las actividades de desarrollo y mantenimiento.

- Control 12.5.1 – Procedimientos de control de cambios: Establece que la implementación de cambios debe controlarse mediante procedimientos formales.
- Control 12.5.2 – Revisión técnica de las aplicaciones después de los cambios del sistema operativo: Recomienda analizar y probar las aplicaciones críticas cuando se realizan modificaciones en los sistemas operativos.
- Control 12.5.3 – Restricciones a los cambios en los paquetes de software: Recomienda que los cambios realizados sobre los paquetes de software estén estrictamente controlados.
- Control 12.5.4 – Fuga de información: Destaca la necesidad de evitar oportunidades de fuga de información durante los procesos de desarrollo y soporte.
- Control 12.5.5 – Desarrollo de software contratado externamente: Establece que la organización debe supervisar y monitorear el desarrollo de software que haya sido contratado externamente.

2.10.6 Categoría 12.6: Gestión de las vulnerabilidades técnicas

La Categoría 12.6, Gestión de las vulnerabilidades técnicas, tiene como objetivo reducir los riesgos derivados de la explotación de vulnerabilidades técnicas conocidas.

- Control 12.6.1 – Control de las vulnerabilidades técnicas: Establece la conveniencia de obtener información sobre vulnerabilidades técnicas, evaluar los riesgos asociados y adoptar las medidas necesarias para tratarlos.

2.11 – Sección 13: Gestión de incidentes de seguridad de la información

La Sección 13 (gestión de incidentes de seguridad de la información) abarca todo lo relativo a cómo una organización detecta, comunica, atiende y documenta los eventos y las debilidades que afectan su seguridad. Comprende el reporte de eventos, el reporte de debilidades, la asignación de responsabilidades, los procedimientos de respuesta, el aprendizaje a partir de lo ocurrido y la recolección de evidencia.

2.11.1 Categoría 13.1: Reportes sobre eventos y debilidades

La categoría 13.1 (reportes sobre los eventos y las debilidades de la seguridad de la información) busca que los eventos y las debilidades de seguridad sean comunicados de forma tal que puedan tomarse medidas correctivas en tiempo real. Reúne dos controles.

- El control 13.1.1 - Reporte sobre los eventos de seguridad de la información: Establece que los eventos de seguridad deben informarse a través de los canales de gestión apropiados tan pronto como sea posible. Esto implica que la organización defina previamente por qué vías y ante quién se notifica, de modo que ningún evento quede sin registrar por desconocimiento del procedimiento.
- El control 13.1.2 - reporte sobre las debilidades en la seguridad de la información: Recomendación que todo el personal, ya sean empleados, contratistas o terceros usuarios de los sistemas, sea instruido para registrar y comunicar cualquier debilidad observada o sospechada en los sistemas y servicios. A diferencia del anterior, no se trata de algo que ya ocurrió, sino de una vulnerabilidad detectada antes de que sea aprovechada.

2.11.2 Categoría 13.2: Gestión de incidentes y mejoras

La categoría 13.2 (gestión de incidentes y mejoras en la seguridad de la información) tiene por objeto garantizar que se aplique un enfoque coherente y eficaz en la gestión de los incidentes.

- El control 13.2.1 (responsabilidades y procedimientos) señala la conveniencia de establecer responsabilidades y procedimientos de gestión que aseguren una respuesta rápida, eficaz y ordenada. Define quién actúa y cómo, de manera que la reacción no dependa de la improvisación.

- El control 13.2.2 (aprendizaje debido a los incidentes de seguridad de la información) recomienda implementar mecanismos que permitan monitorear y cuantificar los tipos, volúmenes y costos de los incidentes. La información resultante permite identificar los incidentes recurrentes o de alto impacto y reforzar los controles vigentes.
- El control 13.2.3 (recolección de evidencia) plantea la necesidad de recolectar, conservar y presentar la evidencia de acuerdo con las reglas que la legislación pertinente establece para su validez. Cuando un incidente puede derivar en una acción legal, civil o penal, la evidencia debe obtenerse y resguardarse de modo que sea admisible.

2.12 – Sección 14: Gestión de la continuidad del negocio

La Sección 14 (gestión de la continuidad del negocio) se ocupa de todos los aspectos que hacen a que la organización siga operando, o recupere rápidamente su operación, frente a un desastre. Contempla la continuidad del negocio y su vínculo con la seguridad de la información, la identificación de los eventos de interrupción, la evaluación de riesgos, los planes de continuidad, su estructura y su prueba y mantenimiento.

La categoría 14.1 (aspectos de seguridad de la información en la gestión de la continuidad del negocio) tiene como objetivo impedir la interrupción de las actividades del negocio, proteger los procesos críticos contra los efectos de fallas o desastres significativos y asegurar su reactivación oportuna cuando corresponda.

- El control 14.1.1 (inclusión de la seguridad de la información en el proceso de gestión de la continuidad del negocio) indica que debe desarrollarse y mantenerse un proceso de gestión de la continuidad que contemple los requisitos de seguridad de la información. De este modo, la seguridad se integra al proceso desde su base y no se trata como un añadido posterior.
- El control 14.1.2 (continuidad del negocio y evaluación de riesgos) exige identificar los eventos que pueden causar interrupciones en los procesos, junto con su probabilidad, su impacto y sus consecuencias para la seguridad de la información. Esta evaluación es el punto de partida para decidir qué proteger con prioridad.
- El control 14.1.3 (desarrollo e implementación de planes de continuidad que incluyan la seguridad de la información) señala la importancia de elaborar e implementar planes que permitan mantener o recuperar las operaciones y asegurar la disponibilidad de la información en los niveles y plazos requeridos, una vez ocurrida una interrupción.
- El control 14.1.4 (estructura para la planificación para la continuidad del negocio) plantea la necesidad de mantener una estructura básica y consistente para todos los planes, de manera que sean coherentes entre sí, permitan fijar prioridades de prueba y mantenimiento y se apliquen de igual forma en toda la organización.
- El control 14.1.5 (pruebas, mantenimiento y reevaluación de los planes de continuidad del negocio) establece que los planes deben probarse y

actualizarse con regularidad, para asegurar que se mantengan vigentes y efectivos frente a los cambios del negocio.

2.13 – Sección 15: Cumplimiento

La Sección 15 (cumplimiento) establece que los requisitos de seguridad de la información deben ajustarse a las leyes, reglamentos, estatutos y obligaciones contractuales que alcanzan a la organización. Abarca el cumplimiento de los requisitos legales, el de las políticas y normas internas, y las consideraciones de auditoría. Se estructura en tres categorías, con un total de diez controles.

2.13.1 Cumplimiento de requisitos legales

La categoría 15.1 (cumplimiento de los requisitos legales) tiene como objetivo prevenir la violación de cualquier ley penal o civil, estatuto, reglamentación u obligación contractual, así como de cualquier otro requisito de seguridad de la información. Cuenta con seis controles.

- El control 15.1.1 (identificación de la legislación vigente) considera conveniente que todos los requisitos legales, reglamentarios y contractuales aplicables a cada sistema se definan de forma explícita, se documenten y se mantengan actualizados.
- El control 15.1.2 (derechos de propiedad intelectual) recomienda implementar procedimientos que garanticen el cumplimiento de los requisitos legales sobre derechos de propiedad intelectual y sobre el uso de productos de software propietario, como el respeto de las licencias.
- El control 15.1.3 (protección de los registros organizacionales) recomienda que los registros importantes se protejan contra pérdida, destrucción y falsificación, en conformidad con los requisitos legales, contractuales y del negocio.
- El control 15.1.4 (protección de datos y privacidad de la información personal) indica que la privacidad y la protección de los datos personales deben garantizarse conforme a la legislación y a las cláusulas contractuales pertinentes.
- El control 15.1.5 (prevención del uso indebido de los servicios de procesamiento de información) establece que los usuarios deben ser disuadidos de utilizar los recursos informáticos para propósitos no autorizados.
- El control 15.1.6 (reglamento de controles criptográficos) recomienda que los controles criptográficos se utilicen en conformidad con los acuerdos, leyes y reglamentaciones vigentes.

2.13.2 Cumplimiento de políticas y normas

La categoría 15.2 (cumplimiento de las normas y políticas para la seguridad de la información y cumplimiento técnico) tiene por objeto garantizar la conformidad de los sistemas con las políticas y normas de seguridad definidas por la organización.

- El control 15.2.1 (cumplimiento con las políticas y normas de seguridad de la información) recomienda que los gestores se aseguren de que todos

los procedimientos de seguridad dentro de su área de responsabilidad se ejecuten correctamente y de acuerdo con las políticas y normas.

- El control 15.2.2 (verificación del cumplimiento técnico) considera conveniente que los sistemas de información se verifiquen periódicamente para determinar su conformidad con las normas de implementación de seguridad establecidas.

2.13.3 Consideraciones de auditoría de sistemas de información

La categoría 15.3 (consideraciones de la auditoría de los sistemas de información) busca maximizar la eficacia del proceso de auditoría y minimizar la interferencia hacia y desde él. Contiene dos controles.

- El control 15.3.1 (controles de auditoría de sistemas de información) establece que los requisitos y las actividades de auditoría que involucren la verificación de sistemas operacionales deben planificarse con cuidado, para reducir el riesgo de interrupciones en los procesos del negocio.
- El control 15.3.2 (protección de las herramientas de auditoría de sistemas de información) indica que el acceso a las herramientas de auditoría debe protegerse, para evitar cualquier mal uso o compromiso.

Capítulo 3 – Sistema de Gestión de Seguridad de la Información (SGSI)

El SGSI integra la estrategia de la organización y está influenciado por necesidades y objetivos, requisitos de seguridad, procesos y estructura organizacional (tamaño). ISO/IEC 27001:2005 ofrece el modelo para establecer, implementar, operar, monitorear, analizar críticamente, mantener y mejorar un SGSI. Su adopción es una decisión estratégica y debe ser proporcional: una situación simple requiere un SGSI sencillo.

El SGSI (ISMS en inglés) es un proceso estructurado y continuo de tratamiento de la seguridad, basado en el ciclo PHVA de ISO 27001:

- Planear: Establecer el SGSI. Contiene políticas, objetivos, procesos y procedimientos relevantes para gestionar el riesgo y mejorar la seguridad.
- Hacer: Implementar y operar políticas, controles, procesos y procedimientos
- Verificar: Monitorear y analizar críticamente. Evaluar y medir el desempeño contra política, objetivos y experiencia; reportar a la dirección
- Actuar: Acciones correctivas y preventivas basadas en auditoría interna y revisión de la dirección, para la mejora continua

Los siete verbos de acción del requisito general (establecer, implementar, operar, monitorear, analizar críticamente, mantener, mejorar) son las fases del ciclo de vida del SGSI.

Establecer el SGSI (Planear)

1. Definir el alcance: negocio, organización, ubicación, activos y tecnología.

2. Definir la política de seguridad: objetivos y dirección general, requisitos legales, contractuales y de negocio; alineada con la gestión del riesgo, con criterios de evaluación y aprobada por la dirección.
3. Definir la estrategia de evaluación de riesgos: metodología y criterios de aceptación.
4. Identificar, analizar y evaluar riesgos: activos, vulnerabilidades, amenazas, daños, probabilidad; decidir si el riesgo es aceptable o requiere tratamiento.
5. Identificar y evaluar opciones de tratamiento: implementar controles, aceptar, evitar o transferir.
6. Seleccionar controles y objetivos de control de la norma.
7. Obtener aprobación de los riesgos residuales.
8. Obtener autorización para implementar el SGSI.
9. Preparar la Declaración de Aplicabilidad, justificando obligatoriamente los controles no seleccionados.

Implementar y operar (Hacer)

Formular e implementar el plan de tratamiento de riesgos; implementar los controles seleccionados; definir métricas e indicadores de eficacia de los controles; implementar un programa de entrenamiento; gestionar las operaciones y los recursos del SGSI; implementar controles para detectar y responder a incidentes.

Monitorear y analizar críticamente (Verificar)

Ejecutar procedimientos de monitoreo (detectar errores, fallas, brechas e incidentes); revisar periódicamente la eficacia; revisar el riesgo ante cambios (organización, tecnología, procesos, amenazas, contratos, legislación); actualizar el plan de seguridad; registrar acciones y eventos que impactaron en el SGSI.

Mantener y mejorar (Actuar)

Implementar las mejoras identificadas; ejecutar acciones preventivas y correctivas; comunicar cambios a los involucrados; asegurar que las mejoras alcancen sus objetivos.

Documentación

La documentación es factor de éxito: demuestra la relación entre resultados y controles, es evidencia de implementación correcta y permite trazabilidad y reproducción.

Declaración de Aplicabilidad: documento formal que lista todos los controles de la norma indicando los aplicados (y el riesgo que tratan), los no aplicados (con justificación), los no aplicables (con justificación) y los adicionales.

Documentos obligatorios para auditar un SGSI:

1. Declaración de política y objetivos del SGSI
2. Alcance
3. Procedimientos y controles
4. Metodología de análisis/evaluación de riesgos
5. Informe de análisis/evaluación de riesgos
6. Plan de tratamiento de riesgos
7. Procedimientos para garantizar eficacia, operación y controles
8. Descripción de la medición de eficacia de los controles
9. Registros requeridos

Control de documentos y registros

Control de documentos: aprobar; revisar, actualizar o rechazar; identificar cambios y versión; disponibilidad de la versión vigente en los puntos de uso; legibilidad; identificar documentos externos; distribución controlada; identificar documentos retenidos.

Control de registros: demuestran conformidad con requisitos, efectividad del SGSI y cumplimiento contractual. Se solicitan en auditoría para comprobar la ejecución de controles.

Dirección y auditorías

El compromiso de la dirección es fundamental: provee recursos, asegura personal competente (formación y registro de competencias) y transmite la importancia del SGSI. Las auditorías internas se hacen a intervalos planificados, según estado e importancia de los procesos y resultados previos, con criterios, alcance, frecuencia y métodos definidos.

Análisis crítico por la dirección

Se hace a intervalos planificados para asegurar conveniencia, adecuación y eficacia; se documenta y se registra.

Entradas	Salidas
Resultados de auditorías internas	Mejora de la eficacia del SGSI
Retroalimentación de partes interesadas	Actualización del análisis de riesgos y del plan de tratamiento
Técnicas, productos o procedimientos para mejorar	Modificación de procedimientos y controles
Estado de acciones correctivas y preventivas	Necesidad de recursos
Vulnerabilidades o amenazas no contempladas	Mejoras en la medición de eficacia de controles
Resultados de indicadores	
Seguimiento de revisiones anteriores	

Recomendaciones de mejora	
Cambios que puedan afectar al SGSI	

Mejora

Acción	Sobre qué actúa	Fin
Correctiva	Causas de no conformidades ocurridas	Evitar su repetición
Preventiva	Causas de no conformidades potenciales	Prevenir su ocurrencia

Controles detallados

Política, seguridad organizacional, gestión de activos, RRHH, física y ambiente, operaciones y comunicaciones, control de acceso; adquisición o desarrollo o mantenimiento; incidentes y continuidad, todos detallados en ISO/IEC 27002:2007.